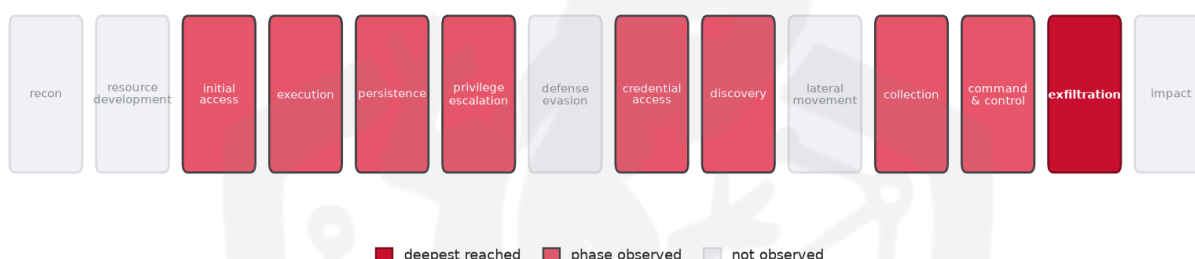


THREAT REPORT: APT37 DEPLOYS TED BACKDOOR AND CURLRAT AGAINST MEDIA AND AUTOMOTIVE TARGETS

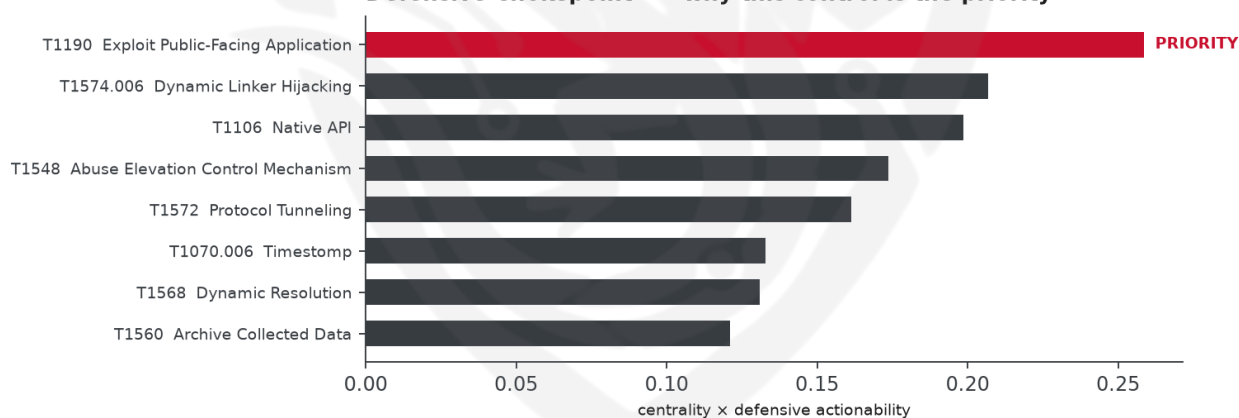
Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: exfiltration)



How far down the attack chain this campaign reached; deepest phase in crimson.

Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The source attributes this activity to APT37, which has been observed operating the ted backdoor and curlRAT malware families. The campaign focuses on organizations in the media and automotive sectors, with no specific country or CVE disclosed in the report. A range of ATT&CK techniques are employed, culminating in data exfiltration. Priority should be given to patching any vulnerable public-facing services, applying a WAF virtual patch, and restricting management interfaces to VPN-only.

Threat Overview

APT37 is leveraging the ted backdoor and curlRAT families to compromise victims. No concrete CVE is identified, as the central vulnerability data is insufficient. The adversary's victimology includes entities

within the media and automotive sectors.

Attack Chain and Priority Control

The observed activity follows a multi-stage chain: initial access is achieved by exploiting a public-facing application (T1190), after which the payload is encoded (T1132.001) and obfuscated (T1027). Native API calls (T1106) launch the malicious process (T1543), which then performs system information discovery (T1082) and process discovery (T1057). Collected data is archived (T1560) and exfiltrated over the command-and-control channel (T1041). Throughout the operation, the threat actor employs techniques such as web service communication (T1102), protocol tunneling (T1572), and indicator removal (T1070.002).

Priority technique: T1190 Exploit Public-Facing Application

Priority control: Patch the affected public-facing CVE immediately; apply a WAF virtual patch; restrict management interfaces to VPN-only.

Infrastructure and Corroboration

No hosting-provider or ASN information was observed for the malicious infrastructure. Abuse.ch corroborates the presence of the CurlBack RAT family within the observed samples. AbuseIPDB reports no indicators with confidence $\geq 80\%$, and the highest confidence seen is 0% .

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1132.001 Standard Encoding
- T1556.003 Pluggable Authentication Modules
- T1543 Create or Modify System Process
- T1539 Steal Web Session Cookie
- T1036.005 Match Legitimate Resource Name or Location
- T1497.001 System Checks
- T1070.002 Indicator Removal
- T1119 Automated Collection
- T1082 System Information Discovery
- T1106 Native API
- T1190 Exploit Public-Facing Application
- T1070.006 Timestamp
- T1572 Protocol Tunneling
- T1560 Archive Collected Data
- T1185 Browser Session Hijacking
- T1574.006 Dynamic Linker Hijacking

- T1548 Abuse Elevation Control Mechanism
- T1562.006 Impair Defenses: Indicator Blocking
- T1568 Dynamic Resolution
- T1102 Web Service
- T1480 Execution Guardrails
- T1057 Process Discovery
- T1041 Exfiltration Over C2 Channel
- T1059.004 Unix Shell
- T1027 Obfuscated Files or Information
- T1071.001 Web Protocols

Analytical Scores

- Priority technique (graph chokepoint): T1190 Exploit Public-Facing Application (centrality 0.2585).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4064; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Rocke	0.4064
Tropic Trooper	0.36
Gamaredon Group	0.3201
Chimera	0.3173
Kimsuky	0.3159

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.
- Malware families corroborated by abuse.ch: CurlBack RAT.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
Domain	img[.]monderhouse[.]space	
Domain	img[.]smartnords[.]site	
Domain	img[.]darklights[.]store	
Domain	img[.]responsive[.]pstatic[.]autos	
Domain	img[.]socialteams[.]store	
Domain	img[.]worksongo[.]store	
Hash	5db1b6d52faf60b4f32d6fd0c7c938e4d05d29a14c32ded4a9668357c08b6a91	CurlBack RAT
Hash	09739441ed4599bac2f8159028f772f71e4b25c8badfff95574e56d7384f3dbe	CurlBack RAT
Hash	fea1bc36632c71e5a839803469ef60ac47595d36b2c50934ac109ade6df06e61	CurlBack RAT
Hash	83f7d565b0465546027052b597af46eae3a199e7a91fcc2ab936341147349130	CurlBack RAT
Hash	7007a78d50a993cb174c685eba96eb442c9507e38fd9d8e5dff712f613ec110	CurlBack RAT
Hash	6cf1b5e92a9c0756f597a5ddefb38eba32961c52efac7ab2a0aa52c639a8fc53	CurlBack RAT
Hash	ed72f4cd8d467b5c5d95ae6aeca4aaeea14d79565d379c1ca5871a714727be16	CurlBack RAT
Hash	feeea9d0bf6ae7396d28271baa51ae50df5169ce5d32a516865856f91abc50b3	CurlBack RAT
Hash	d53c760c23b4405eb04ad0f20ead375440344b3bdf1fb7854ed12e40d155eabe	CurlBack RAT
Hash	2f02b09d61d432134e994ad671258f523bbf289ae6091fd4eae192c60bd51b6f	CurlBack RAT
Hash	8f30b57928934ae67478d0e690c91d046e35a638da098d02922a4a88a0fdb66c	CurlBack RAT
Hash	a1d8af3a6acb731f07f72040eccb3450c1c83d40e29f736c2a63d35388660be4	CurlBack RAT
Hash	12810854c8b2c391b23e2e18b013e873d0369b0637aa3cf993136c07188ba3b8	CurlBack RAT
Hash	009a1e2d7a582a24e50cf2ffc2a005482c8e38f22bf5ed416053855f8d054e1e	CurlBack RAT
Hash	4bb923eb040aa13ca8fd409c31ee4729c60ddff32e350efe1c5a4a9168a065f5	CurlBack RAT
Hash	94630b96f628c96a6bff7904b40ffc9ad67c86f8a4ff6080c3b524831c93f402	CurlBack RAT
Hash	72e70936f0dbe459142a1d867617c35f8d0cce5d18c6a49e1090a2a5adc8e558	CurlBack RAT
Hash	a8bfab4de81a1acb04aacdf757346946b0f5e30f0c9f402004016d0e425119c7	CurlBack RAT
Hash	c8c68e629bba773a10ac80012d10bf19	

Type	Indicator	Context
Hash	ecd427ea8330a4ff73618483e00b9b41	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1190 Exploit Public-Facing Application (initial-access)
- **Observed here:** T1190 Exploit Public-Facing Application was the initial-access control point here; the pivot escalates to execution, drawn from APT37's own documented ATT&CK repertoire.
- **Projected pivot:** T1053 Scheduled Task/Job (execution)
- **Basis:** documented in APT37's own ATT&CK repertoire, and disproportionately paired with Exploit Public-Facing Application across tracked groups (lift 1.5, ~1.5x base rate). Their move, not a generic one.

With T1190 Exploit Public-Facing Application blocked, APT37 could preserve the same objective by pivoting to T1053 Scheduled Task/Job, a technique from APT37's documented repertoire. Defensive countermeasure: Alert on new scheduled tasks (Event ID 4698); restrict schtasks/at to admins; baseline legitimate task creators.

Also plausible (same tactic): T1203 Exploitation for Client Execution (n=13, lift 1.2), T1559 Inter-Process Communication (n=6, lift 1.7)

Detection and hardening for the pivot (T1053 Scheduled Task/Job)

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
 - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
 - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
 - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\
- **Harden:**
 - Restrict schtasks/at to administrators; disable the legacy at.exe
 - Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File